

Topics Covered:

- **NMAP**
- **Nessus**



Description:

In this lab you will have to use and configure Nessus in order to perform a vulnerability scan against the target machine. However you are not told where the target machine is in the network. You only know it is in the same lab network you are connected to.

Note:

1. To start Nessus on kali linux, use the command `sudo systemctl start nessusd.service`
2. And then open the web browser from the search tab and open <https://kali:8834/>
3. You will need to log in and once you logged in you can use Nessus

Steps:

Find a target in the network

We first need to verify which the remote network is. We can do it by running `ifconfig` and check the IP address of our `tap0` interface.

```
tap0      Link encap:Ethernet  HWaddr b6:3d:9d:26:73:b6
          inet addr:192.168.99.13  Bcast:192.168.99.255  Mask:255.255.255.0
          inet6 addr: fe80::b43d:9dff:fe26:73b6/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:31 errors:0 dropped:0 overruns:0 frame:0
          TX packets:8 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:100
          RX bytes:3936 (3.8 KiB)  TX bytes:648 (648.0 B)
```

As we can see the target network is 192.168.99.0/24. Let's run `nmap -sn` in order to discover alive hosts on the network:



```
root@kali:~# nmap -sn 192.168.99.0/24
Starting Nmap 6.47 ( http://nmap.org ) at 2015-02-20 12:06 CET
Nmap scan report for 192.168.99.50
Host is up (0.19s latency).
MAC Address: 00:50:56:B1:D7:8B (VMware)
Nmap scan report for 192.168.99.13
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 11.50 seconds
root@kali:~#
```

The previous screenshot shows that the only host alive in the network is *192.168.99.50* (besides our host: 192.168.99.13).

Identify the target role

Let us run nmap in order to gather as much information as we can about our target. To do this we will run a -A scan as follows:



```

root@kali:~# nmap -A 192.168.99.50

Starting Nmap 6.47 ( http://nmap.org ) at 2015-02-20 12:08 CET
Nmap scan report for 192.168.99.50
Host is up (0.17s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn      Microsoft Windows XP microsoft-ds
445/tcp    open  microsoft-ds     Microsoft Windows XP microsoft-ds
MAC Address: 00:50:56:B1:D7:8B (VMware)
Device type: general purpose
Running: Microsoft Windows XP
OS CPE: cpe:/o:microsoft:windows_xp::sp3
OS details: Microsoft Windows XP SP3
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_nbstat: NetBIOS name: ELS-WINXP, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:b1:d7:8b (VMware)
|_smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: els-winxp
|   NetBIOS computer name: ELS-WINXP
|   Workgroup: WORKGROUP
|   System time: 2015-02-20T03:08:42-08:00
|_smb-security-mode:
|   Account that was used for smb scripts: guest
|   User-level authentication
|   SMB Security: Challenge/response passwords supported
|_ Message signing disabled (dangerous, but default)
|_smbv2-enabled: Server doesn't support SMBv2 protocol

TRACEROUTE
HOP RTT      ADDRESS
1   174.71 ms 192.168.99.50

OS and Service detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.05 seconds
root@kali:~#

```

As we can see in the previous output there are just few services enabled. Moreover, the machine is a Windows machine. Armed with this knowledge we can start configuring our new Nessus policy and scan.

Configure Nessus and run the scan

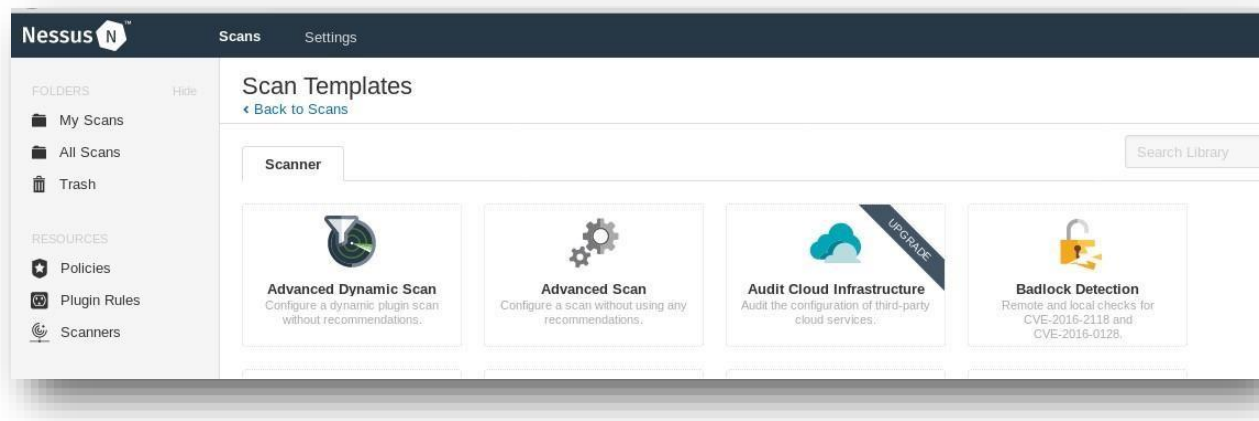
From the previous scans we can guess that the machine is a client (there are no services such as FTP, SSH, Apache or so). Moreover we know its OS is Windows XP, so we can create a new scan policy that will use only specific plugins such as Windows plugins.

In order to run the scan, we need to visit Nessus's web interface on <http://localhost:8834/> first.

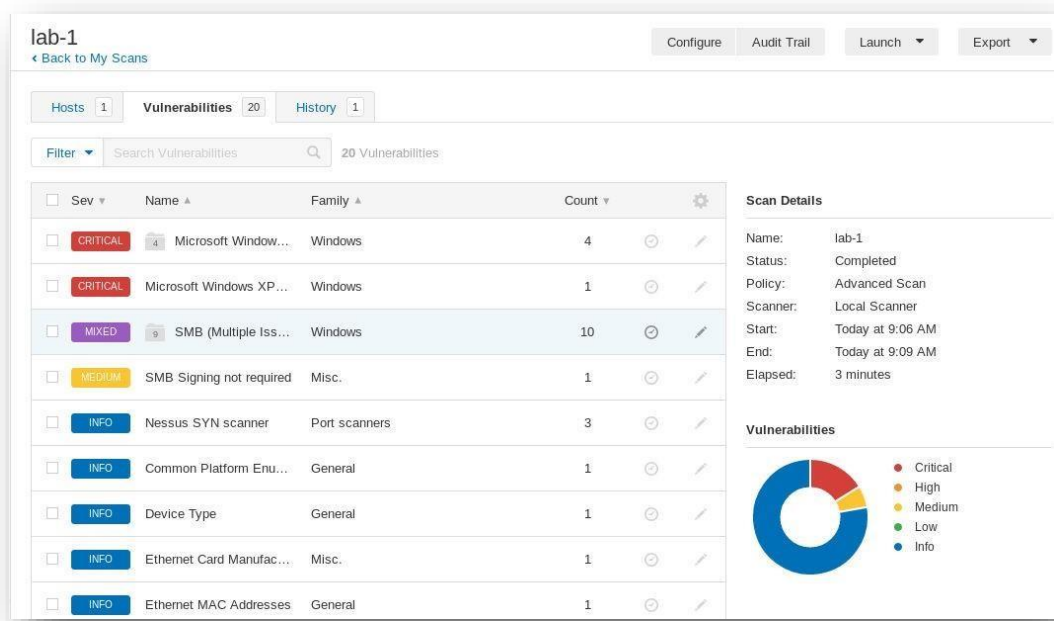
Then we should navigate to **Scans** and choose **New Scan -> Advanced scan**.



We only need to specify the target and the desired name of the scan. Now, we are ready to launch the scan.

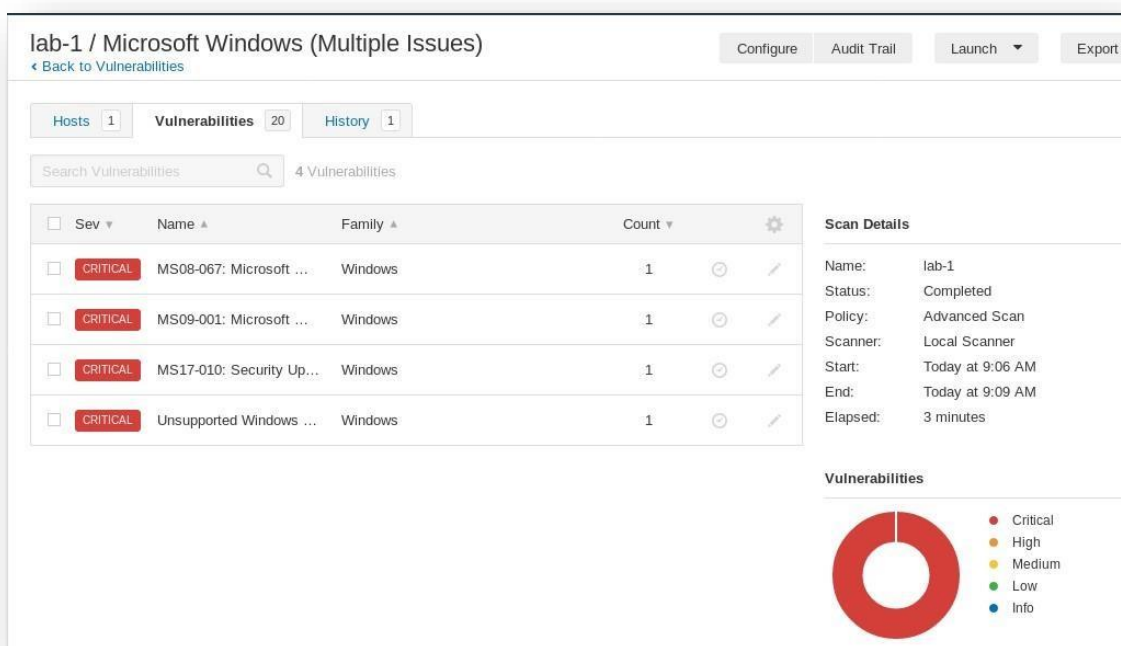


After the scan finishes, we can see the results:



Clicking the first critical vulnerability provides us with a detailed list of the detected issues:





Note: If we wanted to use Windows plugins only so that a faster and a more specific scan is performed, this can be done as follows.

Policy -> New Policy -> Advanced Scan and configure the below.



Nessus

Scans

Settings

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Scanners

nessus_lab / Configuration

Back to Policies

Settings

Credentials

Compliance

Plugins

			STATUS	PLUGIN
DISABLED	RPC	38		
DISABLED	SCADA	316		No plug
DISABLED	Scientific Linux Local Security Checks	2631		
DISABLED	Service detection	452		
DISABLED	Settings	94		
DISABLED	Slackware Local Security Checks	1109		
DISABLED	SMTP problems	141		
DISABLED	SNMP	33		
DISABLED	Solaris Local Security Checks	3623		
DISABLED	SuSE Local Security Checks	12767		
DISABLED	Ubuntu Local Security Checks	4404		
DISABLED	Virtuozzo Local Security Checks	248		
DISABLED	VMware ESX Local Security Checks	122		
DISABLED	Web Servers	1142		
ENABLED	Windows	4167		
ENABLED	Windows : Microsoft Bulletins	1692		

Then navigate to **My Scans** -> **New Scan** -> **User Defined** and launch the scan.

Analyze and export the scan results

From the scan results obtained in the previous step we can see that the machine has some critical vulnerabilities.

The most interesting one is the MS08-067:





This vulnerability allows attackers to execute code remotely! Keep it in mind if you want to exploit the machine!

Optional (Exploit the machine)

In the previous step we found a very interesting vulnerability. Once you finish studying the Metasploit section of the course, come back in this lab and try to exploit it!

